We Audited Five Voice-AI Platforms.

Three Document Recording On by Default.

Four Quick-Starts Never Mention Retention.

We read the settings pages of the five voice-AI platforms clinics build AI receptionists on, and asked one question of each: if the builder changes nothing, what does the platform keep? Then we scripted 200 inbound calls from 200 synthetic patients, rendered each one in text shapes modelled on how speech-to-text services write a call, and ran the standard privacy scan over all of them. Measured, not guessed.

Wen-Chia “Belle” Chang · Agenvana

All patient data synthetic · all methods open-source and reproducible

THE ONE FINDING

Picture one inbound call to a clinic's AI receptionist. A patient gives her name, her date of birth, a number to call back on, and then the reason she is calling: a repeat script for her blood-pressure medication, and could the doctor also look at the results from last week.

That call makes five stops. The microphone feeds a speech-to-text service. The text goes to a language model, turn by turn. The model writes a booking into the practice system. The platform files the recording, the transcript and an AI summary of the call. And a post-call webhook hands a copy of all of it to whatever the builder wired up: a spreadsheet, a CRM, a "memory" so the agent recognises her next time.

Only one of those five stops is supposed to hold her data. The booking.

That is the system built to hold it, access-controlled and regulated. Every other copy the call leaves behind is a copy that needs its own decision: keep it, or not.

We read the settings pages of the five voice-AI platforms clinics build these receptionists on, and asked one question of each: if the builder changes nothing, what does the platform keep?

Three of the five document that they record every call by default. Four of the five document that they keep the transcript. The fifth does not say.

Every compliance switch whose default is documented ships off, and two of them cost extra. How long the copies stay depends on which platform the builder picked: two years on ElevenLabs, and on Retell, indefinitely. **Four of the five quick-start guides never mention retention, HIPAA or deletion.** The one that does gives it a single line, listed as a feature.

Nobody in this story meant any harm. The builder followed the quick-start. The platform documented its defaults. The patient answered the questions she was asked. The copies exist anyway. This issue is about where they are, how long they last, and what the tools you would use to find them actually find. Measured, not guessed.

EXECUTIVE SUMMARY

The one page to read

What we did. Three things, all published with the report so anyone can check them. **First**, a retention-defaults audit: we read the developer documentation of the five voice-agent platforms (Vapi, Retell AI, Bland AI, ElevenLabs Agents, Synthflow), the telephony layer beneath them (Twilio), a speech-to-text vendor (Deepgram) and two language-model providers (OpenAI, Anthropic), on 14 September 2026, and recorded for each what is stored by default, for how long, and what a builder has to do to change it. Every cell is the vendor's own sentence, with the page and the date. **Second**, a scan: we scripted 200 inbound receptionist calls from 200 synthetic patients (built from the public Synthea generator; no real person's data was used), rendered each call as the transcript a speech-to-text service would produce, in three text shapes modelled on documented vendor behaviour, and ran the standard open-source PII scanner over all of them. **Third**, a memory test: we loaded the transcripts into a memory store built on the database's default settings with an unfiltered semantic query, a deliberately naive design of our own, and asked it to recognise returning callers.

What we found.

- **Recording and keeping the transcript is the documented default on most of the platforms we audited, and the quick-starts do not say so.** Three of the five platforms document that they record every call by default; four of the five document that they keep the transcript; Synthflow documents neither default. Every compliance or zero-retention mode whose default state is documented ships off. Default retention is two years on ElevenLabs and indefinite on Retell. Four of the five quick-start guides never mention retention, HIPAA or deletion.
- **The same 200 scripted calls, two transcript shapes, and the standard privacy scan misses very different things.** In the formatted shape (capitals, punctuation, numbers as digits), the scan missed at least one annotated identifier in **49 of 200 scripted calls**. In the spoken-words shape (lower case, no punctuation, "oh four five four nine five five"), it missed at least one in **172 of 200**, and recognised **0 of 280** phone, Medicare, Social Security and insurance numbers as what they were. Which shape a builder's transcripts take depends on settings inside the speech-to-text vendor that the builder rarely sees. The two shapes differ in several ways at once, so the gap is a comparison of text shapes, not the effect of a single switch.
- **In its default configuration, the scan flagged 0 of 440 health details in 200 scripted calls at actionable confidence.** Every one of the 200 scripted callers mentioned a condition, a medication or an allergy: 440 health details in all. The standard PII scan, in its default configuration and with its Australian identifier pack added, flagged **0 of 440 at actionable confidence**, in every transcript shape. The tool ships an optional medical recogniser that is not enabled by default; we did not test it, so whether it would change that zero is unmeasured. The point is what a builder gets out of the box and assumes a "PII scan" covers.
- **Our deliberately naive call memory, an unfiltered semantic search over the transcripts, is not a phone book.** Asked "who is calling" by phone number, an unfiltered semantic search over the 200 transcripts returned another synthetic caller's transcript first in **199 of 200** queries, and one hub transcript came back first in 197 of them; this was never an exact identifier lookup, and a builder who filters on a phone field would not see it. Every returned transcript contained that other caller's health information, because every transcript does.

Why this matters to your business. A clinic whose builder kept the defaults on Retell holds a recording and a transcript of every patient call on the vendor's servers indefinitely; on ElevenLabs for two years. Those copies sit outside the practice system, and unless someone puts them there, outside the clinic's retention schedule and its own assurance checks. And in our scripted test, the standard PII scan in its default configuration flagged none of 440 health details at actionable confidence, which means the one check a careful builder might run on the copies they do control can flag the identifiers and leave every condition and medication unflagged. This is not a story about a malicious platform or a careless builder. It is a story about defaults, and defaults are the one thing nobody is paid to look at.

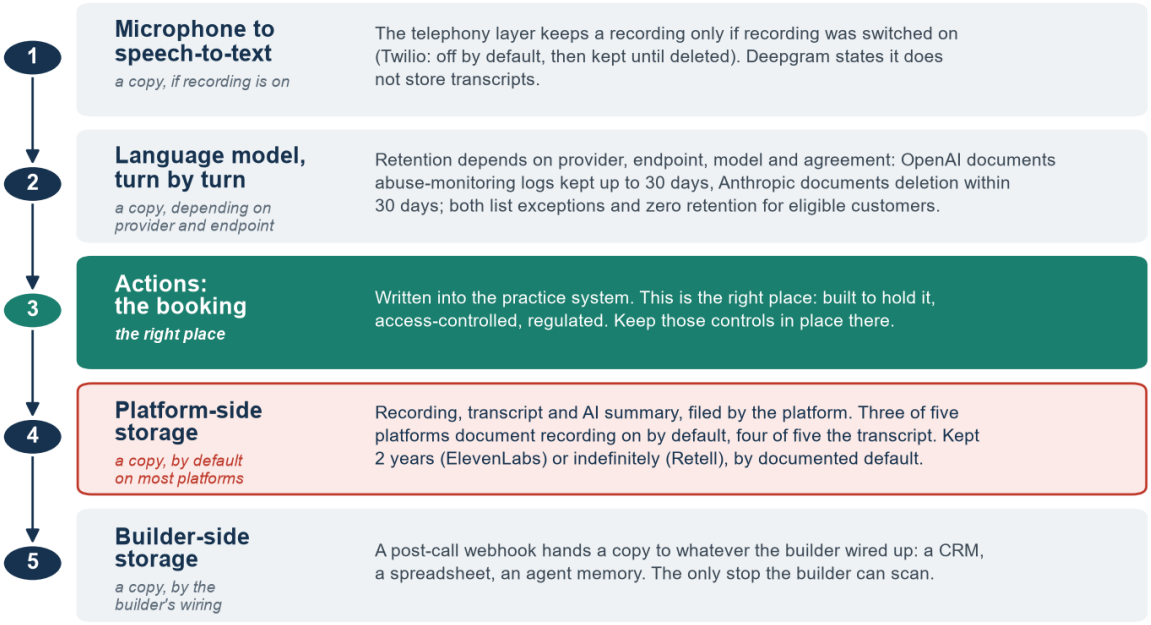
The good news, and it is real. Every finding in this report has a control that reduces it: configuration, design or an agreement, each of which needs checking once it is switched on. The controls exist: retention settings, compliance modes, zero-retention tiers, a webhook that lets you keep the structured fields and discard the rest. They are switched off. Some platform protections sit behind a paid tier or add-on; the rest cost nothing but attention. The What to do section is the list: start by checking what your privacy scan actually detects, then reduce what you collect and retain.

I review AI-agent deployments for a small number of teams. Reply if you want the checklist.

THE FINDING

The five stops, and what each one keeps if nobody touches a setting

One call, five stops. Only one of them is the right place.



Defaults as each vendor documented them on 14 September 2026; the full matrix is published with the report. The booking (stop 3) belongs in the practice system, which is built to hold it. Other copies depend on vendor defaults, configuration and the builder's integrations; each needs its own retention decision.

Stop	What happens	Who holds a copy, by default (as documented on 14 September 2026)	The control that exists
1. Microphone to speech-to-text	Audio becomes text	The telephony layer only if recording was switched on (Twilio's `Record` defaults to false; recordings then stay until deleted, storage billed per minute per month). Deepgram states it does not store transcripts	Recording toggle; retention settings; STT vendor choice
2. Language model, turn by turn	The model reads everything said	Retention depends on provider, endpoint, model and agreement: OpenAI documents abuse-monitoring logs kept up to 30 days by default, with endpoint exceptions; Anthropic documents deletion within 30 days as standard, with model and feature exceptions. Both document zero-retention for eligible customers and a BAA route (Anthropic's self-serve in the console; OpenAI's for provisioned organisations on eligible endpoints)	Provider choice; a signed no-retention or BAA agreement
3. Actions	The booking is written to the practice system	**The practice system. This is the right place. Nothing to prevent here**	Access control and retention in the practice system, as always
4. Platform-side storage	Recording, transcript, AI summary filed by the platform	See the table on the next page: on by default on most platforms, kept for two years (ElevenLabs) or indefinitely (Retell)	Retention settings; compliance mode; zero-retention tier; contract
5. Builder-side storage	Post-call webhook delivers transcript, summary and structured data to the builder's own CRM, sheet or agent memory	Whatever the builder wired up. Fully under the builder's control, and the only stop the builder can scan	Keep the fields, discard the transcript; scan what you hold

THE FINDING, CONTINUED

The platform defaults, as documented on 14 September 2026

Every cell is the vendor's own page; the full matrix with verbatim quotes and URLs is published with the report and is re-verified quarterly.

Platform	Records audio by default	Keeps the transcript by default	Compliance or zero-retention mode	Its default state	Default retention
Vapi	**Yes** (`recordingEnabled` default true)	Yes	HIPAA mode and Zero Data Retention: both org-level paid add-ons, mutually exclusive, not enableable by API	Off	Up to 14 days for calls and 30 days for chats on pay-as-you-go; Enterprise configurable *
Retell AI	**Yes**	Yes	`data_storage_setting` (everything / everything except PII / basic only) and a retention-days field	Off (`everything`; retention `null`)	**Indefinite** ("no automatic deletion")
Bland AI	No (`record` default false)	Yes (transcript and summary in call details)	Org-level recording lifespan (1 to 1825 days, or -1); "zero-retention processing" on the trust page only	Not documented	Not documented
ElevenLabs Agents	**Yes** ("audio recordings are enabled")	Yes (disabling audio keeps transcripts)	Per-agent Zero Retention Mode; workspace ZRM on Enterprise	Off ("history preservation enabled")	**2 years**
Synthflow	Toggle; default not documented	Toggle; default not documented	Save toggles, a 30-day auto-delete toggle, PII redaction toggle	Not documented	"Depends on your plan"

** As read on 14 September 2026; by 1 October the page no longer stated these periods.*

Reading the table honestly: **three of five document recording on by default** (Vapi, Retell, ElevenLabs); Bland documents it off but keeps the transcript and a summary anyway; Synthflow does not document the initial state of its toggles, so it counts as unknown, never as on. **Four of five document transcript storage on by default.** Every compliance mode whose default is documented ships off, and Vapi's two are paid add-ons. A business associate agreement, required where a HIPAA-covered clinic has the platform process or store electronic protected health information on its behalf, is self-serve and free on Retell, Enterprise-only on ElevenLabs, and a paid add-on on Vapi (the page said Enterprise or add-on when we read it on 14 September and a paid compliance add-on with any usage plan by 22 September; the matrix keeps both).

The quick-start test. We opened the first page a new builder is sent to on each platform and looked for the words retention, HIPAA or deletion in the text of the page itself (navigation menus were not counted; two of the five link retention pages from a sidebar). **Four of five quick-starts contain none of them.** ElevenLabs' contains one line, "Conversation retention to view conversation history and improve its performance", listed as a feature, with no default and no deletion. No quick-start states a retention default. This is the mechanism behind the whole issue: the platforms document their defaults, on other pages, which four of the five quick-start texts never point to.

A setting the builder rarely sees decides how numbers reach the transcript. The speech-to-text vendor's settings decide whether "my number is oh four five four nine five five nine eight oh" reaches the transcript as words or as digits. Deepgram, the transcriber Vapi lists first, ships with both of its number-formatting switches off, so its default transcript writes a phone number as words; AssemblyAI formats numbers by default on pre-recorded audio; Azure's display text always does. A builder gets one

of those transcript shapes depending on which vendor the platform chose for them and how it was set. The next section compares scripted transcript shapes that differ in several properties at once, so it does not isolate that setting; it shows what the shape of the text does to the one safety net most builders think they have.

THE FINDING, CONTINUED

Same 200 scripted calls, two transcript shapes, one privacy scan

We wrote 200 inbound calls to an AI receptionist, one per synthetic patient (100 Australian, 100 US), across five reasons for calling: a booking, a repeat prescription, a results follow-up, a reschedule and a billing query, 40 of each. Each caller gives what callers give: a name, a date of birth, a number to call back, and then the reason, which brings in a condition, a medication, sometimes an allergy, a relative's name, the GP's name, an email, an address, a Medicare number or an insurance member ID. That is 1,120 identity items and 440 health items across the 200 scripted calls.

Each call was rendered in three text shapes inspired by documented speech-to-text behaviour (no audio was transcribed; the renderings change several properties at once, so a difference between two shapes is a difference between text shapes, not the isolated effect of one vendor setting):

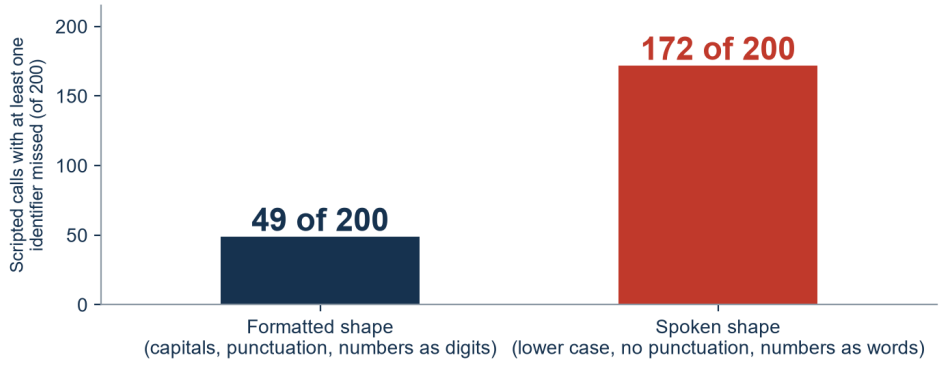
Shape	What it models	The same phone number
Formatted	Smart formatting on: capitals, punctuation, digits	`0454 955 980`
Digits	Numbers as digits, everything else lower case, no punctuation	`0454955980`
Spoken	Formatting off: lower case, no punctuation, numbers as words	`oh four five four nine five five nine eight oh`

Every transcript was scanned with Microsoft Presidio, the standard open-source PII engine, in its stock configuration. An item counts as caught if any finding of any label overlaps it, at a score of 0.4 or above (the "actionable" tier from Issue #1; the tool's low-confidence guesses do not count). A third tier, "caught with the correct label", is reported beside it, because in the spoken shape the generous tier counts a phone number flagged as a date as a catch.

Identity items, 1,120 per shape, stock defaults:

Shape	Caught at actionable confidence	Caught with the correct label	Scripted calls with at least one identity item missed
Formatted	1,065 of 1,120	1,010 of 1,120	**49 of 200**
Digits	917 of 1,120	789 of 1,120	132 of 200
Spoken	784 of 1,120	568 of 1,120	**172 of 200**

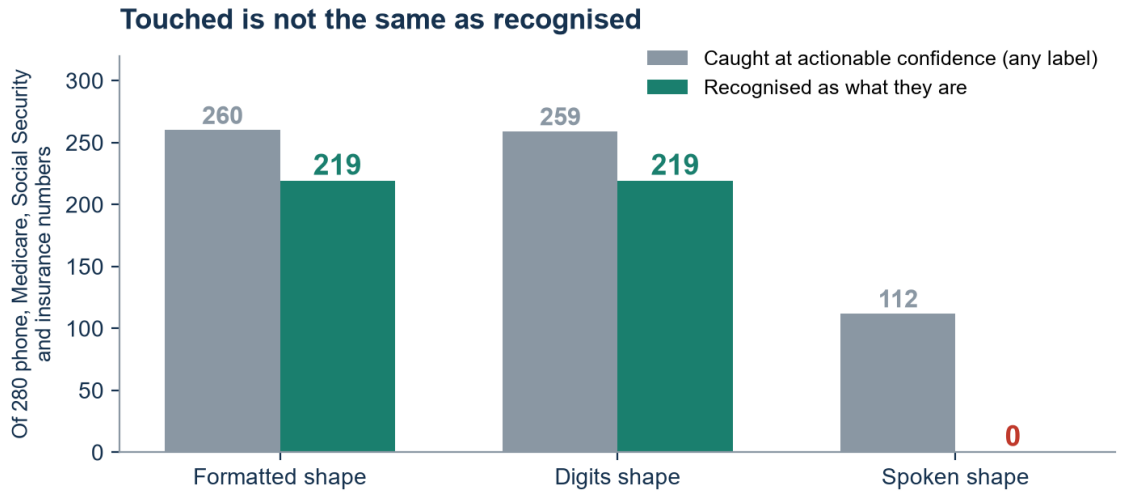
Same 200 scripted calls. Two transcript shapes. One privacy scan.



Presidio stock defaults, actionable confidence (score 0.4 or above). The calls are scripted and synthetic; no audio was transcribed. The two shapes differ in several properties at once, so this compares text shapes, not the effect of one vendor setting.

The numeric identifiers are where the transcript shape decides everything. Phone, Medicare, Social Security and insurance numbers, 280 items per shape, from the 200 scripted calls, stock defaults, actionable tier:

Shape	Caught at actionable confidence	Recognised as what they are
Formatted	260 of 280	219 of 280
Digits	259 of 280	219 of 280
Spoken	112 of 280	**0 of 280**



280 numeric identifiers in 200 scripted calls, Presidio stock defaults. The grey bar counts any label at score 0.4 or above overlapping the number; the coloured bar needs the right label. In the spoken shape, every phone number the scan touched was labelled as a date.

In the scripted spoken shape, 66 of the 200 phone numbers were touched by the scanner, and all 66 were labelled as dates. All 19 Social Security numbers were touched, all 19 labelled as dates. Of the 40 Medicare numbers, 20 were touched, all as dates. The 21 insurance member IDs have no recogniser in any shape (4 touched in the formatted shape, 0 correctly labelled). A date label at 0.85 confidence on a Social Security number is a misclassification. Whether that span would then be redacted depends on the downstream policy, which we did not test; a report built on the labels would count it as a date.

Texture, verbatim from the run. Call CALL-001, a US repeat-prescription call. In the formatted shape the scan found `US_SSN@0.85 '999-87-7767'` and `PHONE_NUMBER@0.75 '(617) 782-1563'`. The same call in the spoken shape:

```
truth : ssn 'nine nine nine eight seven seven seven six seven'
        phone 'six one seven seven eight two one five six three'
found : DATE_TIME@0.85 'nine nine nine eight'
        (nothing on the phone number at all)
```

And CALL-004, an Australian billing call in the spoken shape: the Medicare number `six five four two six four two nine zero two` and the mobile `oh four six three one five nine eight five four` produced `LOCATION@0.85 'hermiston'` (the caller's surname), `DATE_TIME@0.85 'four eight'` and `DATE_TIME@0.85 'five two'`. Neither number was touched.

What survives the spoken shape, and what does not. Dates of birth survive well: "the twenty sixth of november nineteen forty seven" is still a date to the language model underneath (186 of 200 correctly labelled). GP names survive (112 of 120 correctly labelled in the formatted shape, 116 of 120 in both lower-case shapes; "dr lucio" is a person either way). Caller names and relatives' names fall from 183 and 110 correctly labelled in the formatted shape to 143 and 79 in the spoken shape; both lower-case shapes sit near 150 caught against 187 formatted, and because the shapes differ in more than casing,

no single cause is isolated. Emails fall from 120 of 120 correctly labelled to 0 of 120 ("kirk dot reinger" is flagged as a person).

The switch that saved Issue #1 does not save a transcript. Presidio's optional Australian recogniser pack lifts formatted and digit-run Medicare numbers from 0 to 40 of 40 correctly labelled, and takes the formatted shape's missed-calls count from 49 to 46. In the spoken shape, every figure is identical with the pack on or off: still 172 of 200 scripted calls with a miss, still 0 of 280 numbers recognised.

THE FINDING, CONTINUED

The call memory, built naively on purpose

The last stop is the one builders reach for most eagerly: give the agent a memory, so it can greet a returning patient by name. We loaded the 200 formatted transcripts into a Chroma collection with its default embedding function, the exact query shape the database's own getting-started page demonstrates (it does not recommend identifying callers this way; the design is ours and it is naive on purpose), and asked the memory who is calling. The table is a scripted synthetic corpus queried by semantic search, which is not a lookup; read the paragraph under it before quoting a row.

The agent asks its memory	Top result is a different synthetic patient	True transcript in the top 10
"Incoming call from {phone number}"	**199 of 200**	18 of 200
"Caller {first name} {last name}"	72 to 73 of 200 (three runs)	176 to 179 of 200
"Caller {name}, date of birth {DOB}"	61 to 62 of 200 (three runs)	185 to 186 of 200

Say this carefully, because it is easy to misread. The phone-number row is not the memory picking the wrong patient 199 times in the sense of 199 near-misses. A semantic search is not a lookup: a query that is mostly a number string has almost no meaning to an embedding model, and the search collapsed onto one hub transcript, which came back first for 197 of the 200 queries (the memory returned only 2 distinct transcripts at rank one). The honest claim is narrower and still useful: in this synthetic corpus, an unfiltered semantic query built from a phone number returned another synthetic caller's transcript first in 199 of 200 cases, and it was never an exact identifier lookup. A builder who stores the phone number as a metadata field and filters on it would not see this (our collection stored only the region, so no such filter was possible). The name rows are ordinary retrieval failing for ordinary reasons: Synthea shares surnames, so "Caller Micheal Lang" returned Jermaine Lang's call. In those two rows the wrong-first-result counts varied by one between runs and the top-ten counts by up to three, because the nearest-neighbour search is approximate, which is why they are written as ranges.

What the rows share is the consequence. In every wrong case, in every run, the transcript that came back contained the other patient's health information, because every one of the 200 transcripts does. A memory built from raw transcripts hands the agent a stranger's medical history on the wrong lookup, and the agent has no way to know.

HOW WE MEASURED

Method, and everything wrong with it, stated by us first

- **The audit.** Nine vendors' developer documentation, read on 2026-09-14; every load-bearing cell (Vapi's recording default, Retell's indefinite retention and default-stored list, ElevenLabs' two-year default, Bland's `record` default, Deepgram's `smart_format` default) was re-fetched independently the same day and matched verbatim. Cells read from a trust page or pricing page rather than developer docs are marked as vendor marketing in the matrix and are never load-bearing here. "Not documented" means we looked and the vendor does not say, which is itself a finding. **Every default in this report is true as of 14 September 2026 and will change.** The matrix keeps history: when a default moves, a new dated row is added and the old one stays, because "this platform used to keep transcripts for two years by default" is also a finding. The access date is printed beside every table in this report. Two cells moved between the audit and publication. Vapi's HIPAA page said "Enterprise subscription or a separately purchased HIPAA add-on" on 14 September and "a paid compliance add-on with Usage only or any Success Package" on 22 September; the report says "paid add-on". Vapi's call-recording page stated "Pay-As-You-Go: Up to 30 days for chats and 14 days for calls" when we read it on 14 September and no longer stated those periods when we re-read it on 1 October; the platform table keeps the 14 September reading, marked as such, and no Vapi retention period is used anywhere else in this report. The matrix carries both rows for each. OpenAI's BAA request page could not be opened from our environment on either date, so the report does not rely on it.
- **The fixture.** 200 synthetic patients built from Synthea, MITRE's public synthetic-patient generator: names, dates of birth, active conditions and current medications come from Synthea's tables; allergies come from Synthea where the patient has one recorded, and a scripted penicillin allergy is substituted where the roster has none (62 of the 80 allergy mentions are that substitute). Phone numbers, emails, addresses, Medicare numbers (valid check digit) and insurance member IDs are fabricated in ordinary formats; Synthea's own 999-prefixed Social Security numbers are kept for the US cohort. No data from any actual patient was used. Contact identifiers were not checked against allocation, so accidental correspondence to a real contact detail is not excluded.
- **Scripted, not recorded.** The dialogue is templated: five scenarios, a fixed turn structure, one call per patient. The *amount* of disclosure per call is therefore ours, and nothing in this report treats it as a finding. The scan and memory results are a comparison of identifier shapes within one fixed scripted corpus; we did not vary the amount of disclosure.
- **No audio was processed.** The three text shapes model documented speech-to-text output with perfect recognition. Real transcripts add recognition errors (in a benchmark published in August 2026, even the best of 12 speech-recognition systems recovered every workflow-critical value, such as an identifier, in only 68.7% of 300 recordings, roughly 206 of them), which can move spans, labels and denominators in either direction. These figures are neither an upper nor a lower bound on real transcripts. They are a controlled comparison of text shapes. The shapes also differ in several properties at once (casing, punctuation, name surfaces, email surfaces, number rendering), so no result here isolates one vendor setting. Where our rendering departs from a vendor's own example, it is disclosed: our digit runs are concatenated where Deepgram's example keeps spaces (more favourable to number recognisers), and our spoken shape lower-cases sentence-initial capitals that the vendor's example keeps (less favourable to name recognition).
- **The scanner, and how it was scored.** presidio-analyzer 2.2.364 on its default large English model (which it downloads itself on first use; Issue #1 ran on the small model, so this is more generous to the tool on names and locations, and it changes nothing about the pattern recognisers where the spoken-shape gap lives). Two configurations: stock, and stock plus the optional Australian pack. Three tiers, generous to the tool: any confidence; actionable (score at least 0.4); correct label. Partial overlap counts at every tier, so a city inside an address earns full address credit; the tiers measure whether the tool touched and labelled the item, not whether the whole span would be redacted. Insurance member

IDs and the three health kinds have no accepted label, so they can only score zero at the correct-label tier, which is why the health result is reported at the actionable tier.

- **The health result is about the tested configurations, not about the tool's ceiling.** Neither tested configuration enables a medical recogniser. Presidio ships an optional one (`MedicalNERRecognizer`, extra dependency, not enabled by default); it was not evaluated, so its performance is unknown. At any confidence, 9 of the 440 health items were touched, all of them the medication `b12` overlapped by a below-threshold driver-licence pattern; 0 of 440 at actionable confidence, in every shape and both configurations. The 0 of 440 is a fact about what a builder gets out of the box.
- **Off-target findings.** The scan also produced 450 (formatted), 388 (digits) and 388 (spoken) actionable findings outside our annotated spans. This is not a false-positive rate: the agent repeats the caller's first name, unannotated, in 40 calls, and a legitimate person hit there counts as off-target. The samples show dates on "today" and "Monday", URL fragments inside email addresses and the repeated first name. We report the count and do not build on it.
- **The memory test.** chromadb 1.5.9, default ONNX MiniLM embeddings, no metadata filter (the collection stores only the region). One embedding model, one corpus, one query template. The 199 of 200 shows that, for this corpus, an unfiltered semantic query did not act as a phone lookup and collapsed onto a hub transcript; it is not a general statement about semantic search, and it is not how a careful builder would identify a caller.
- **We ran it three times and kept all three sets of raw results.** The roster and every transcript are byte-identical across runs by construction; the scan and the memory lookups are re-executed each run so stability is measured, not assumed. Identical in all three runs: every scan figure in this report, every health figure, and the phone-number memory row (199 of 200, hub transcript first 197 times, 18 in the top 10). Varied: only the two name-based memory rows, by one at the top rank and by up to three in the top-10 counts, which is why they are written as ranges. Presidio's scoring did not vary at all.
- **Sample sizes.** 200 calls, 40 per scenario, 19 to 200 items per identifier kind. Enough for the categorical findings (0 of 280, 172 of 200); not enough for decimal-point claims, which is why the report prints counts.
- **The separate reviewer.** Before drafting, the data package was reviewed three times by a different model from the one that produced it (Codex, 14 to 15 September 2026): 28 findings in round one, 9 confirmed, 13 narrowed, 6 refuted; every narrowing and refutation was applied and the reviewer closed all 28 by round three. Three claims did not survive that pass and are gone: that the scan caught none of the 200 phone numbers in the spoken shape (true only at the correct-label tier; 66 were flagged as dates, so we quote the tier every time); that the spoken-shape gap was the effect of one vendor switch (it is a text-shape comparison); and that the scanner has no concept of health information (it ships an optional recogniser we did not test). What we got wrong on the way is part of the method, because the method is the product.

WHAT IT MEANS

Consequence, by vertical

The honest frame first. Every incident in this issue is a storage, consent or disclosure failure around conversational data. None is a vector-database breach, and we have still not found a publicly documented one. That should worry you rather than comfort you: we could not find a breach notice that says where the copies were, or a standard forensic tool that inspects a transcript store, and in our experience most organisations do not know their receptionist has one. What can be documented is that the copies exist by default on most of the platforms we audited, that they are kept for two years (ElevenLabs) or indefinitely (Retell), and that when they are exposed, they are exposed at scale. In March 2026 security researcher Jeremiah Fowler reported finding three unprotected databases belonging to Sears Home Services' AI voice agents, holding audio recordings, chat logs and text transcripts of customer calls from 2024 to 2026; his write-up counted 1,442,577 audio recordings (Wired, reporting the same finding, puts it at 1.4 million audio files plus plain-text transcripts), and access was restricted the day after he disclosed it. Nobody attacked a model. Someone found the copies.

The right-place doctrine, which is the whole argument. Capturing a patient's name, date of birth and reason for calling is not the leak. Writing them into the practice system is the job working correctly: that system is built to hold them, access-controlled, backed up on purpose and covered by the clinic's obligations. **The risk is every extra copy the call leaves behind on the way there that nobody needs, nobody accounts for, or nobody protects.** The goal is never "no sensitive data anywhere". It is "data lands only in the systems designed to hold it, and nowhere else". By that standard, a build on the documented defaults of the three platforms that record by default leaves, per call, a recording and a transcript on the platform, plus whatever the post-call webhook delivered to wherever the builder pointed it, plus whatever the model provider retains under its own default. One correct home, and copies the builder never decided to make.

Health

A patient calling for a repeat script says the medication. A patient calling about results says the condition. In our 200 scripted calls, every caller did, and the standard privacy scan, in its default configuration, flagged 0 of those 440 details at actionable confidence. In a real clinic, medication and condition details linked to an identifiable patient are health information and therefore sensitive information under Australia's Privacy Act. For organisations covered by the Act, collecting sensitive information generally requires consent and must be reasonably necessary for their functions or activities, subject to statutory exceptions (Privacy Act 1988, sections 6 and 6FA; Schedule 1, APP 3). A privacy scan that misses those details does not remove those obligations. The details sit in the transcript, where our default scan missed all 440 scripted health details at actionable confidence. For a HIPAA-covered clinic, using a platform to process or store electronic protected health information without a required business associate agreement violates HIPAA; on the five platforms we read, that agreement is self-serve on one, Enterprise-only on one and a paid add-on on another. Ahpra's guidance on AI in healthcare emphasises informed consent when patient data is involved. Its discussion of AI scribes and recorded consultations also warns of possible criminal implications when recording occurs without consent. That warning is not a specific ruling on reception agents. For a clinic deploying an AI receptionist, the practical implication is to establish how consent, recording and patient-data handling will work before taking live calls.

Legal

A law firm's intake agent hears the one fact a firm protects hardest: that this person is a client, and what about. In a family-law, criminal or insolvency matter, the transcript of the first call is the sensitive fact, and by default it exists on the platform for as long as the platform's default says (indefinitely on Retell; two years on ElevenLabs), and in the firm's own CRM if the webhook was pointed there. The consent cases are already running: a class action filed in April 2026 against a US health system alleges its ambient recording tool captured consultations "without obtaining meaningful, informed consent", and the vendor is not a defendant. The deployer is. In August 2026 the US Federal Trade Commission finalised orders against three firms over an "Active Listening" advertising service; the FTC said the service was not based on voice data and that consumers had not opted in; the settled orders concern what the firms told customers, not proof that any listening occurred. Recording is a legal act with conditions attached, and on three of the five platforms we audited the default makes it the act you perform first.

Financial services and brokers

Loan and billing calls are identifier-dense by design: a name, a date of birth, a phone number, a Medicare or insurance number, an address, an email, all in one transcript. In our scripted spoken-shape transcripts, the 20 Medicare numbers and 19 Social Security numbers the default scan touched were all labelled as dates; those are exactly the raw material of the fraud that arrives months later wearing a lender's logo. A scam is credible in proportion to the accurate personal data behind it. The harm from a leak usually arrives later, as the scam it armed, and the trail is rarely traced back to a broker's voice agent. When that wave reaches your customers, the investigation walks backwards, and "we run a PII scan on the transcripts" is a sentence that will not survive the first look at what the scan can label in a spoken transcript.

In my view, providers need to explain plainly how they handle data, sensitive data included, and protect the data entrusted to them. But they cannot be expected to design every deployer's workflow. The builder has to connect those protections to the actual use case: what the agent collects, where it sends the data, and what it keeps. If we treat leak prevention as the provider's job alone, I worry we encourage careless deployments and expect providers to carry responsibilities that builders must share. So my ask of every builder and deployer is simple: when a voice agent runs, data flows. Know where it goes, decide where it belongs, and put protections at those boundaries. Both sides have work to do.

The responsibility, for builders. Choosing a platform with privacy features does not complete a clinic's compliance work. Under HIPAA, a covered clinic using a platform to process or store electronic protected health information needs the required business associate agreement in place; business associates also have obligations of their own. A provider's offer of a BAA is not the same as an executed agreement covering the deployment. For the agency building the receptionist, the practical responsibility is to make those requirements visible before launch: establish which agreements are needed, which protections are enabled, and who is responsible for the patient information the system collects. Those decisions belong in the deployment process, before the first patient call.

WHAT TO DO

Eight steps, in priority order

The house rule: never state the fear without the fix. The list is in priority order, not a deployment timeline: the agreements in item 6 must be in place before live calls, whatever order you work in. Start by checking what your scan can detect, then reduce what you collect and retain. The steps cover testing, consent, configuration, design and agreements; some platform protections require a paid tier or add-on.

1. **Check what your privacy scan actually detects.** A PII scan is not necessarily a health-information scan, and its default configuration may miss identifiers written as spoken words. In our 200 scripted calls, the standard scanner in its default configuration flagged 0 of 440 medical details at actionable confidence, and 0 of 280 phone, Medicare, Social Security and insurance numbers as what they were in the spoken shape. The tool ships an optional medical recogniser that is off by default and that we did not test, so whether it would change that zero is unmeasured; the point is what you get by running the scan the way the README shows. If your evidence that a transcript store is clean is "the PII scan came back clean", that result alone does not establish that the store is free of sensitive information. Scan for what you actually hold: conditions, medications, allergies, and numbers written as words.
2. **Settle consent and recording before the first live call.** Decide whether the agent records at all, how callers are told, and where consent is captured, and write it down; on three of the five platforms we audited the default answer to "does it record" is yes until someone changes it. Check the consent and recording requirements that apply to your jurisdiction and sector before the first call; this is a decision, not a setting.
3. **Open the retention settings the quick-start did not walk you through.** On every platform in this report a retention control exists; four of the five quick-starts never mention it, and the fifth links it without stating a default. Set retention to the minimum your records policy allows; on Retell that means setting the retention-days field at all, because its default is indefinite. If your platform offers a compliance mode or a zero-retention tier, check its suitability and your eligibility, then enable the appropriate one: on Vapi, HIPAA mode and Zero Data Retention are separate paid add-ons, mutually exclusive, and cannot be enabled through the API; on ElevenLabs, Zero Retention Mode is per agent, and disabling audio alone still keeps the transcript. Do the same at the telephony layer: if recording was ever switched on in Twilio, the recordings are still there, billed monthly, until someone deletes them.
4. **Extract the fields. Discard the transcript.** On the platforms we read, the post-call webhook can carry the full transcript and a recording or a link to one, depending on configuration. The right-place doctrine in one sentence: parse the name, date of birth, phone number and appointment out of the webhook into the practice system, and do not store the payload. A transcript you never kept is a transcript nobody can leak, subpoena, or find in an unprotected database two years later.
5. **Never build agent memory from raw transcript text.** The call-memory section is what it produces: a store where every entry is a stranger's medical history, retrieved by a search that is not a lookup. If the agent needs to remember a returning caller, store the structured preference ("prefers Dr. Lee, Tuesdays") keyed on an identifier you filter on, and nothing else.
6. **Sign the agreements before the first call, not after the first question.** A data-processing agreement with the platform, the required business associate agreement for a HIPAA-covered deployment in which the provider processes or stores electronic protected health information on the clinic's behalf (self-serve and free on Retell; Enterprise-only on ElevenLabs; a paid add-on on Vapi; self-serve in the console at Anthropic; OpenAI documents BAA-eligible endpoints for provisioned organisations), and a retention arrangement with the model provider that fits the use case, after checking which models and features are eligible (Anthropic's covered models require 30-day retention and are not available with zero retention; OpenAI's retention controls need approval and eligible

endpoints). These documents do not create the duty; they record who carries it.

7. **Ask which speech-to-text vendor your platform picked for you, and how it writes numbers.** You will not find this in the quick-start either. The answer shapes whether your transcripts say `0454 955 980` or `oh four five four nine five five nine eight oh`, and the scan section shows how much the shape of the text matters to any scan you run afterwards, even though our scripted shapes differ in more than that one setting.
8. **Scan and monitor every store you control, put it behind access control and a patch cycle, and document the ones you cannot reach.** Stop 5 is fully yours, and the Sears exposure was three databases with no protection in front of them at all. Stop 4 is the platform's, and whatever residue the platform keeps internally after you minimise is honestly beyond your reach: that is a vendor-selection question and a contract question, not a scan. Perfection is not the bar. Defensibility is: shrink the copies to the systems built for them, prove what you hold, and write down what you knowingly keep and why. A clinic that can say those three sentences to a regulator is in a different universe from one that cannot.

APPENDIX

Methodology detail, reproduction and sources

Reproduce it. The script, the pinned environment, the Synthea-derived roster and the raw results for all three runs are published with the report. From the repository root:

```
python -m venv reports/tools/voiceenv
reports/tools/voiceenv/Scripts/python.exe -m pip install -r reports/tools/requirements-voice.txt
reports/tools/voiceenv/Scripts/python.exe reports/findings/src/voice_transcripts.py
```

(On macOS, substitute `reports/tools/voiceenv/bin/python`.) Verified on presidio-analyzer 2.2.364, spaCy 3.8.16, chromadb 1.5.9, Python 3.13.5, Windows, seed 20260914. Rebuilding the roster from Synthea needs the public sample `synthea_sample_data_csv_apr2020.zip` (8,982,431 bytes; SHA-256 in the script header) and the `--synthea` flag; the committed roster makes that optional.

The three transcript shapes, in one call. CALL-000, an Australian booking call, the caller's phone number and email as each shape writes them:

```
formatted : 0454 955 980            kirk.reinger34@bigpond.com
digits    : 0454955980              kirk dot reinger34 at bigpond dot com
spoken    : oh four five four nine   kirk dot reinger three four at bigpond dot com
            five five nine eight oh
```

In the formatted shape the scan found the phone number and the email correctly. In the spoken shape it found the date of birth ("the twenty sixth of november nineteen forty seven", labelled as a date) and did not touch the phone number.

The audit, in full. The Platform Posture Matrix is published beside the report: every cell carries the vendor's page, the verbatim sentence and the date it was read (2026-09-14), with developer documentation distinguished from trust and pricing pages. It is re-verified quarterly and keeps history; the next re-verification is due 2026-12-14.

What happened after Issue #2. Issue #2 reported that ChromaDB's documented cleanup command leaves every deleted vector in the index file, and we filed it with the maintainers as `chroma-core/chroma#7662` on 31 August 2026, the day of publication, saying we would note it in the report if a fix was coming. On 8 September an outside contributor reproduced our numbers exactly on their own machine and opened a documentation fix, pull request #7693, which adds a "What vacuum does not erase" section to the vacuum reference ("a space-reclamation command, not a secure-erasure operation") and corrects the CLI example. We confirmed on 13 September that the wording closes the gap. **As of 30 September 2026 the pull request is open and unmerged, awaiting maintainer review.** Nothing is fixed

yet; the community wrote the fix in eight days, and it is in review.

Sources. Platform Posture Matrix, 2026-09-14 edition (Vapi, Retell AI, Bland AI, ElevenLabs Agents, Synthflow, Twilio, Deepgram, OpenAI, Anthropic developer documentation) · *VoiceCodeBench: Evaluating Exact Structured-Token Recovery in Automatic Speech Recognition*, arXiv:2608.28916 · *Meddies-PII*, arXiv:2609.12544 · *Do Speech Tokens Leak Voiceprints?*, arXiv:2607.16870 · *HearSay Benchmark*, arXiv:2601.03783 · Chim et al., *Evaluating privacy leakages in LLM-driven ambient clinical documentation*, Frontiers in Digital Health, 2026 · Fowler, Sears Home Services exposure write-up, 2026-03-17 (read 2026-09-14; the URL returned 404 on 2026-09-22 and is excluded from the Wayback Machine) · Newman and Burgess, "Sears Exposed AI Chatbot Phone Calls and Text Chats to Anyone on the Web", Wired, 17 March 2026 (read by Belle on 2026-09-23; cited beside the primary for the audio count) · *Washington v. Sutter Health*, N.D. Cal. 4:26-cv-03012, complaint filed 2026-04-08 · FTC final orders, Cox Media Group and others, 2026-08-27 · FTC and states v. Hims & Hers, 2026-07-29 · Ahpra, *Artificial Intelligence in healthcare* guidance · Privacy Act 1988 (Cth), sections 6 and 6FA and Schedule 1 APP 3, legislation.gov.au · US Department of Health and Human Services, *Guidance on HIPAA and Cloud Computing* · chroma-core/chroma issue #7662 and pull request #7693 · Microsoft Presidio documentation (supported entities, including the optional medical recogniser) · the public findings package and verification log, published with the report. Source URLs and read dates for the platform documentation are in the Platform Posture Matrix; the research papers and the verification log are in the public findings package. Nothing marked secondary in the tracker is cited.

About

The AI Data Security Report is a monthly, methods-open report on where AI pipelines actually leak data. Measured, not guessed. Every measurement of our own can be rerun from the published script; third-party figures are cited to their source. Author: **Wen-Chia “Belle” Chang**, Agenvana (hybrid form, per the Issue #1 attribution decision; LinkedIn byline stays Belle Chang). The author's work on data-layer privacy for AI systems, including its voice-agent embodiment, is patent pending. Contact: via LinkedIn (Belle Chang) or github.com/Agenvana.

Issue #1 (July 2026), *"Your AI's Privacy Filter Speaks American. It Missed 1 in 3 Australian IDs."* Issue #2 (August 2026), *"We Asked an AI Database to Delete 100 Patients. All 100 Were Still There."*